

If you followed our conversation, you already know what security is. Our job is easy now. Let us define some terms around our conversation above.

1. **Assets** : You were trying to protect your money, isn't it? It is called Assets. Money is your Asset in our conversation that you were trying to protect.

Definition : Assets are something that has value and is worth protecting.

Security is all about ensuring that the assets are kept protected all the time as much as possible within your capabilities or means.

2. **Controls (or Countermeasures)** : So, how did you actually safeguard your money? You didn't leave the Debit Card around and you memorized your PIN. Isn't it?

Definition : Any countermeasures or actions that you take to safeguard an asset are called Controls.

So, in our conversation, you have put two controls in place to safeguard your money – first is to keep your Debit Card with you and second is to memorize your PIN. You are a security champion!

3. **Threat** : Hey you told me that you don't trust everyone with your money, isn't it? That unknown everyone who can do evil to you or can harm you is called a Threat.

Definition : A threat is a person or an entity that can exploit an asset bypassing your controls (if they are weak controls and not enough to safeguard your asset).

You knew there are threats around your money and you protected it so well. You are a security champion.

4. **Vulnerability** : What if you left your Debit Card and PIN on the table for anyone to get hold of them and use? I hear you scream, "Come on, why would I do that to myself?". Exactly, you would not want to create a situation in which your assets can be harmed. This is precisely called addressing (or avoiding) a Vulnerability.

Definition : Vulnerability is the weakness or lack of controls around assets.

I am happy that you have put two good controls (keeping your Debit Card safe and memorizing your PIN) and you avoided the vulnerability around your money (asset).

5. **Risk** : So far, you would agree that leaving Debit Card and PIN unattended poses a likelihood that someone might just grab them and use them.

Definition : The likelihood of a harm occurring to an asset is called Risk.

6. **Exposure** : Someday suppose you do accidentally leave your Debit Card behind and your PIN was known to someone, you could actually lose some or all your money. That particular day or rather that particular situation of you forgetting your Debit Card behind could lead to an exposure.

Definition : Exposure is an instance of being harmed.

So, if you got exposed anytime, immediately change your PIN and take a lesson in security to apply controls always around assets so that you do not have future exposures. I am sure you won't have exposures because you are a security champion already, aren't you?

Let me summarize the above terms in a simple block diagram as shown in Fig. 1.1.1.

If you are feeling good about what we talked about so far, believe me, you have started your security journey on a high note. The several chapters and topics that you read in this book (howsoever complex or dry they look at first) are all written to help you effectively do just ONE thing – **Safeguard your Assets**.

- If you know what you are
 - trying to protect
 - and from whom
 - and how
- you understand security. There is nothing else to learn.

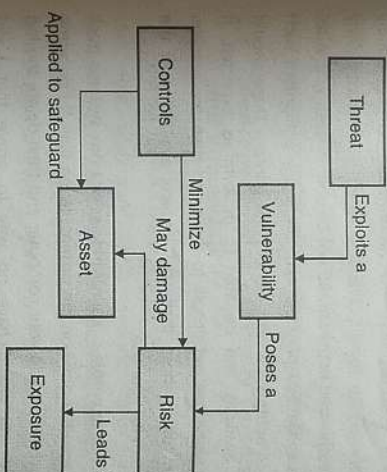


Fig. 1.1.1

1.2 Concept Building - Information Security Concepts

Q. Enlist security goals. Discuss their significance.

MU - Dec. 18, 5 Marks

Q. A secure e-voting system is to be designed. Discuss the security goals that must be met and enlist mechanisms for the same. **MU - May 19, 5 Marks**

Now that you have a general understanding of security, let's set some context about Information Security. When we say information security – what exactly are we protecting? What is the asset? The asset here is "Information" or more precisely "Digital Information". The information could be about your Facebook user account, Online bank account, OS password, email or pretty much anything that touches a computer system.

There are 3 tenets (or pillars) of security :

1. Confidentiality
2. Integrity and
3. Availability

These tenets in short are also called as the CIA triad or any other combination of the first letters in their words. These are also sometimes called **goals of security**.

Let's dive deeper into each one of them.

1.2.1 Confidentiality

Definition : Confidentiality can be defined as, an act of protecting information from unauthorized disclosure to an entity.

It ensures that the protected information is kept secret throughout its lifetime and is made available only to the authorized entities as and when needed.

The information should be :

1. **Protected at Rest** : When stored on the disk network
2. **Protected in Motion** : When transmitted over the network
3. **Protected during Use** : When processing

Remember our conversation from Debit Card and PIN? How did you protect your PIN and provide confidentiality to it?

1. **Protected at Rest** : You didn't write it down. You kept it in your mind. No one could know or use it except you.

2. **Protected in Motion** : You physically moved to an ATM (carrying your mind and the protected PIN there) instead of revealing it to anyone.

3. **Protected during use** : You watch out if someone is looking at your fingers as you punch the PIN on the ATM keyboard

In terms of digital information, confidentiality is enforced using several mechanisms :

- (a) Encryption
- (b) Access control
- (c) Data classification

We would be studying them at depth in later chapters.

1.2.2 Integrity

Definition : Integrity can be defined as, an act of protecting information from unauthorized modification by an entity.

It ensures that the information remains intact and no unauthorized entity can modify it. Any modification to the

Information is allowed only if the entity is authorized to do so. The information requires to maintain its integrity throughout its lifetime.

For example : During criminal investigations, any evidence that you collect is protected from touching or any modifications to ensure that those evidences can be used during court proceedings. If an evidence is tampered, it is not admissible in the court and cannot be used. Another example is email. If I send you an email and someone changes it before you read it, you might get wrong information, or it could be severely damaging to our relations.

In terms of digital information, integrity is enforced using several mechanisms :

1. Hashing
 2. Access Control
 3. Data Classification
 4. Input and output sanitization
- We would be studying them at depth in later chapters.

1.2.3 Availability

Definition : Availability can be defined as, an act of protecting information from unauthorized destruction by an entity.

It ensures that the information is adequately protected to remain available when it is needed. Any unauthorized entity should not be able to destroy it. Also, the availability principle extends to any equipment such as computers, network devices and printers. These should be available and be able to perform as expected. If someone can get access to them and then prevent you from using these then that impacts availability of the system for your use.

For example : Your Windows or Linux systems track all activities done on the system via log files. If I do some mischief around your computer and then delete the log files, you would have no way to prove that I did something to your computer. The availability of log files is crucial to ensure that the system is adequately monitored and protected from any security mishaps.

Availability is generally enforced using several mechanisms :

1. Access control
2. Isolation
3. Back up
4. Disaster Recovery
5. Business continuity processes

We would be studying them at depth in later chapters.

Let's summarize the 3 security principles with the help of Fig. 1.2.1.

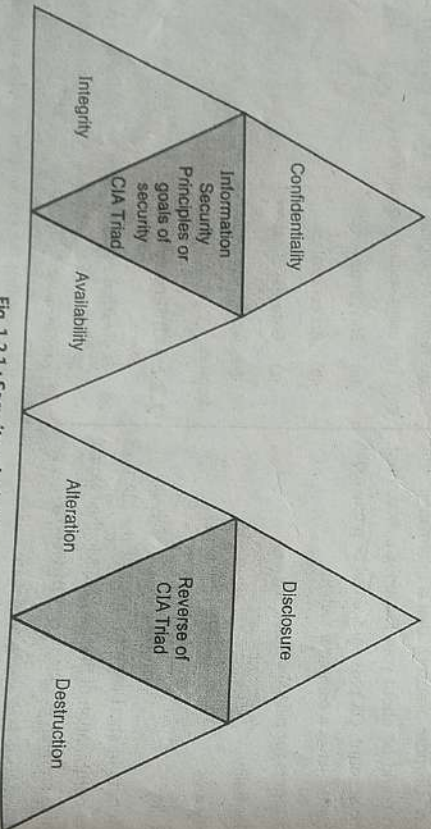


Fig. 1.2.1 : Security principles

Confidentiality, Integrity and Availability are the 3 core principles of security. Ensuring that you understand the objectives behind these principles is crucial to your success in the information and cybersecurity domain.

1.3 Concept Building - Security Threats and Vulnerabilities

From our previous discussion on Debit Card and PIN, you now understand what security threat and vulnerabilities mean. Threats can exploit your assets and vulnerabilities are situations that could possibly lead to such an exploit. Let us review some of the security threats and vulnerabilities commonly found in the context of information security.

1.3.1 Security Threats

There are several security threats to an information system. Some of them are briefed as following :

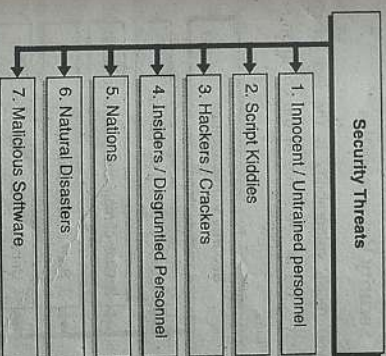


Fig. 1.3.1 : Security threats

1. Innocent / Untrained personnel

- These could be your employees, household members or any person who does not understand intricate complexities of security.
- These people believe the information presented to them and often are soft targets of several frauds. These can get easily convinced and can be pushed to do harm to your organization (say by sharing critical details) or to any other critical asset.

- As a countermeasure, you should provide security training time to time and enforce the idea that security is everyone's responsibility.

2. Script Kiddies

- These are just exploiting the systems for fun. They have a lot of free time and can go around the internet to find systems that have weak controls.

- Once a system is found, they can play games, watch movies, download other software or just send some random messages on the screen.

- These do not have sophisticated skills to exploit weaknesses themselves and usually depend on attack tools or software.

- As a countermeasure, test your website and software against general attack tools and ensure that any weaker controls are sufficiently addressed.

3. Hackers / Crackers

- These are people who have sophisticated computer security skills. They have a deep understanding of how various protocols, services, operating systems, drivers, network equipment etc. work and can thus launch sophisticated attacks on such information systems.

- They usually hide their presence and activities to ensure that they are unnoticed and can exploit the systems for a long time without getting detected.

- As a countermeasure, invest in penetration testing of your website and software and ensure that all the security findings are adequately addressed.

4. Insiders / Disgruntled personnel

- These people are on your side, but they have malicious intent to impact your systems. They might have grudge on you or the organization and typically exploit the systems to take revenge. Insider threats are extremely hard to detect since you might believe that their actions are part of their job and may not suspect them or monitor them very closely.

- As a countermeasure, use access control to provide least possible permissions required to carry out one's job.

- You should evaluate the permissions time to time and ensure that those permissions are still relevant to the job done by the person.

5. Nations

- Many a times, nations spy on each other and want to steal information related to country defence, forces, arms, and other intellectual property and confidential information that can severely damage the reputation of the country or its economics.
- These attacks are highly sophisticated but have huge impact on nations.
- **For example :** You might have heard of Russian involvement in the US elections.
- As a countermeasure, nations typically protect the sensitive information by limiting information sharing only amongst the high-ranking officials. They deploy top notch security solutions, processes and continuously monitor their operations to detect any unauthorized activities.

6. Natural Disasters

- Natural disasters such as flood, earthquake, lightning, etc can severely damage the information systems (remember availability as one of the tenets of security?) and could impact information availability.
- As a countermeasure, you invest in backup, business continuity processes and disaster recovery solutions that can quickly bring back the systems and information to avoid large impact on your business.

7. Malicious software

- These are software programs written with malicious intent. The purpose of these programs is to harm the information systems or extract useful information in an unauthorized manner.
- As a countermeasure, you install such software detection tools.
- These tools could be anti-virus, anti-malware, anti-spyware, intrusion detection system, intrusion prevention system, etc. We would explore this, in depth in the subsequent section.

1.3.1(A) Comparison between Security Threats

Sr. No.	Threat	Skills required	Impact	Detection Possibility
1.	Innocent / Untrained personnel	None	Low - High	Low
2.	Script Kiddies	Medium	Low - High	High
3.	Hackers / Crackers	High	High	Low
4.	Insiders	Low	High	Low
5.	Nations	High	High	Low
6.	Natural Disasters	None	High	Low
7.	Malicious Software	Medium	High	High

1.3.2 Security Vulnerabilities

As you recall, vulnerability is the lack of controls around assets. Let us see some of the common security vulnerabilities.

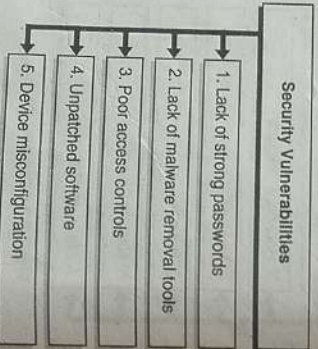


Fig. 1.3.2.: Security Vulnerabilities

1. Lack of strong passwords

- Passwords are everywhere. For quick and easy recall, you tend to choose simple passwords such as your name, date of birth, school name, etc. People, who know you, are generally aware of this information as well and can try to use this information as your password.

- Additionally, if you tend to choose simple English words as your passwords, someone can do a dictionary-based attack (more on that later) and can find out your password.

- As a countermeasure, always choose a complex password that is the combination of uppercase letters, lowercase letters, digits and special characters. Change your passwords regularly and do not use old passwords.

2. Lack of malware removal tools

- There are several malwares that can be installed on your device as you browse through various websites on the internet.

- If you do not have a good malware removal tool, overtime, your device might be compromised and impacted.

- As a countermeasure, install a reputed malware removal tool and update its definitions time to time.

3. Poor access controls

- Do you allow everyone to be an administrator on your system? Can anyone access anything? If your answers are yes, you probably have not thought through the "Least Privilege" principle yet.

- You should only grant enough permissions as required by the job at hand. No more and no less. Understand the different permissions required and assign them accordingly.

4. Unpatched software

- Vendors release security patches (software bundles that fix something in the software installed previously)time to time to fix security vulnerabilities found.

- If you do not install these patches, your system could be prone to exploit because the required security fix to stop the exploit is not installed.

- As a countermeasure, install software updates as released by the vendor specially the ones that carry security fixes.

5. Device misconfiguration

- Quite a few times, we configure devices for maximum ease and minimum security. For example, have you locked your phone with a password or a PIN?

- If you get a security warning, do you click ok even without reading and understanding what the warning is about? When installing an app on your phone, do you ignore to review device permissions that the app would have? Such ignorant behaviour and poor device configuration could weaken the controls that the vendor has put out of factory.

- As a countermeasure, carefully review your device settings and ensure that they are tuned to provide adequate security.

1.4 Concept Building – Access Control and Attacks

Let's understand the basics of access control mechanisms. These mechanisms are at the core of designing security in information systems and are often the target of attacks.

1. Identification

Definition : Identification (in short ID) is defined as, a way to claim an entity's presence with respect to the process being carried out.

- This means that during a process, your presence (or your consent) is ascertained (or established).

- **For example :** When you try to login to your Facebook account, you provide your Email or Phone number to establish your presence during the login process.

- There are several other forms of identification that we use today such as Aadhar Card, PAN Card, Voter ID, Debit Card, Admit card, etc. All of these identification methods bring a sense of credibility that you are present, or you give your consent to complete a particular process.

2. Authentication

Definition : Authentication is defined as, a way to ensure that the entity is indeed what it claims to be.

- This means that providing just the ID is not enough. You must additionally prove that the ID belongs to you.
- **For example :** Even if I know your Facebook email address or phone, I cannot login as you until I also know the password. Thus, knowing just the ID is not enough. We need to prove that the ID belongs to us and that is what is precisely called authentication.
- It is for this reason that you need to additionally sign when you submit Aadhar card or PAN card as an ID proof to ensure that someone didn't just use the photocopy of those IDs without your permission (or consent).
- Some of the ways to authenticate an ID are passwords, biometric (like your Aadhar finger prints or phone sensor), PIN (like for Debit Card), or OTP (SMS that you get to confirm transaction).
- 3. **Authorization**
 - Definition : Authorization is defined as, a way to determine what resource an entity can access.
 - Once you have provided your ID and have been successfully authenticated, the next step is authorization where the system determines if you have the permission to access the desired object.
 - **For example :** Even if you have a valid voter ID card but if your name is not on the electoral list at a particular area booth, you won't be allowed to vote.
 - Having authenticated, ID is one thing and getting access to the resource is another. Just because you have an authenticated ID, does not mean that you have automatically access to the resources. So, authenticated ID is a must for authorization but that does not always guarantee that you would be allowed access.
- 4. **Accountability**
 - Definition : Accountability is defined as, a way to record your actions.
 - Suppose, you used a system to take print outs. That system logs this action (pretty much like you record attendance in lab or classroom) to build a trace (evidence or proof) that you used the printer.

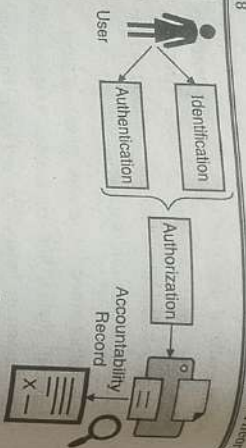


Fig. 1.4.1 : Access control steps

- If you were not supposed to use the printer, the evidence can be used to find you accountable for using it without permissions and could result in particular consequences.
- Accountability is a key determinant of how securely a system is operating. The logs generated are continuously monitored and necessary alarms are raised if any entry is found to be suspicious.
- Let's summarize the 4 access control steps with the help of Fig. 1.4.1.
- 5. **Non-repudiation**
 - Definition : Non-repudiation is defined as, a way to prove your actions.
 - It is used in conjunction with accountability and the CIA triad. Non-repudiation provides an assurance that someone cannot deny their actions later on.
 - **For example :** If I sent you an email, I cannot later deny that I did not. To send an email, I must have used my email ID and password and then sent it over to you over a secure network where no one could change the email body. If you can establish all of these facts truthfully, you have proven that I sent that email and thus established non-repudiation.
 - Now that you understand the access control steps and security pillars (CIA), let us understand security attacks and what these attacks are actually targeting.

1.4.1 STRIDE Model

STRIDE model is often cited as a reference when designing security for information systems.

Table 1.4.1 : Attacks on Information Systems

Attack Category	Security Property that is attacked
Spoofing	Authentication
Tampering	Integrity
Repudiation	Non-repudiation
Information Disclosure	Confidentiality
Denial of service	Availability
Elevation of Privilege	Authorization

1. **Spoofing**
 - When someone tries to steal your identity, it is called spoofing. Spoofing is also called as impersonating someone or something.
 - **For example :** If I try to login to your Facebook account using your email address and password guesses, I am trying to spoof or impersonate your identity.
 - Spoofing can also be used for fake news, fake websites, fake or malicious files or anything else that could be mistaken for being real. The target of spoofing attacks is to crack authenticity (of person, file, website, news or anything real).
2. **Tampering**
 - When someone tries to do an unauthorized modification to something, it is called tampering. You would have heard of cricketers tampering with the ball to suit their requirements. It is a punishable offense.
 - Similarly, in information systems, if you try to tamper with say files, emails, or any other information in an unauthorized way, it is called tampering. Basically, you are trying to attack the integrity of the object by making such alterations.
3. **Repudiation**
 - In this, you are trying to falsely claim that you didn't carry out a particular action.
 - **For example :** You didn't send an email or didn't visit a website. Remember your childhood days when you broke something, and you try to escape the punishment saying that you didn't actually break it and then your parents finding proofs that it was indeed you who broke it. That's precisely what is non-repudiation.
 - In repudiation attacks, you are trying to destroy evidences that someone can use to falsify your denial claims.
4. **Information Disclosure**
 - This pertains to unauthorized revealing of any confidential information.
 - In these attacks, the attacker wishes to know the confidential information and tries to crack controls around it to get hold of such confidential information.
5. **Denial of Service**
 - In this type of attacks, the purpose of attack is to make the information system or its services unstable or unavailable to perform its assigned activities.
 - **For example :** If you can succeed to bring Flipkart website temporarily down, it might mean severe loss of business for Flipkart and the customers may go to a different website for placing their urgent orders.
6. **Elevation of Privileges**
 - In this category of attack, the attacker tries to get elevated (higher) privileges (permissions / authority) over resources.
 - **For example :** If you are only a user on a system and you try to attack the system to become an administrator on the system, it is called an elevation of privileges attack.

1.5 OSI Model

Definition : The Open Systems Interconnection model (OSI model) is a conceptual model that characterizes and standardizes the communication functions of networked communications without diving into complexities of protocols, architecture and the underlying technologies.

The OSI model consists of 7 layers as shown in the Table 1.5.1. Each layer interacts with the layer above and below it and passes on the respective protocol data units encapsulated into their respective headers.

Table 1.5.1 : Layers of OSI model

Layer Number	Layer Name	Protocol Data Unit	Function
7	Application	Data	Application Interface – APIs, UIs
6	Presentation	Data	Data translation between networking and application
5	Session	Data	Manage communication sessions between sender and receiver
4	Transport	Segment, Datagram	Reliable transmission data
3	Network	Packet	Network packet addressing and routing
2	Data Link	Frame	Transmission of data between two nodes
1	Physical	Binary	Actual communication over physical media

Note that each OSI layer protocol adds its own information to the data packet.

Definition : The process of adding layer specific information and passing on the data to the next layer below is called encapsulation.

Encapsulation happens top – down (From Application to Physical Layer).

Definition : The process of removing layer specific information and passing on the data to the next layer above is called decapsulation.

Decapsulation happens bottom – up (from Physical to Application Layer).

Following Table 1.5.2 is a quick reference summary for various protocols at the respective OSI layers.

Table 1.5.2 : Protocols used in various OSI layers

Layer Name	Protocols Used
Application	HTTP, FTP, SMTP, etc.
Presentation	JPEG, MPEG, TIFF, ASCII, etc.
Session	NFS, RPC, etc.
Transport	TCP, UDP, SSL, etc.
Network	IP, ICMP, OSPF, etc.
Data Link	ARP, PPP, Ethernet, etc.
Physical	ISDN, DSL, 10Base-T, etc.

Note : Discussing OSI Model in-depth is beyond the scope of this book. It is assumed that you have covered it in detail in your subjects on networking. A general high-level overview is presented here as a refresher.

1.5.1 The OSI Security Architecture

The objective of the OSI model is to permit the interconnection of heterogeneous computer systems so that useful communication between application processes may be achieved. At the various OSI layers, the security controls must be established in order to protect the information exchanged between the application processes (or the connected computers or devices). Such controls make it difficult to obtain the information in any unauthorized way.

Definition : The OSI Security Architecture identifies the basic security services and mechanisms and their appropriate placement at the various layers.

OSI security functions are concerned only with the OSI layers involved in the communications path. It does not include other security controls such as securing the operating system or the application process itself. Let's learn about the various security services and mechanisms placed at the OSI layers.

1.5.2 Security Services

Definition : Security services are safeguard controls recommended to be placed at the various OSI layers.

The various security services are listed as shown in Fig. 1.5.1.

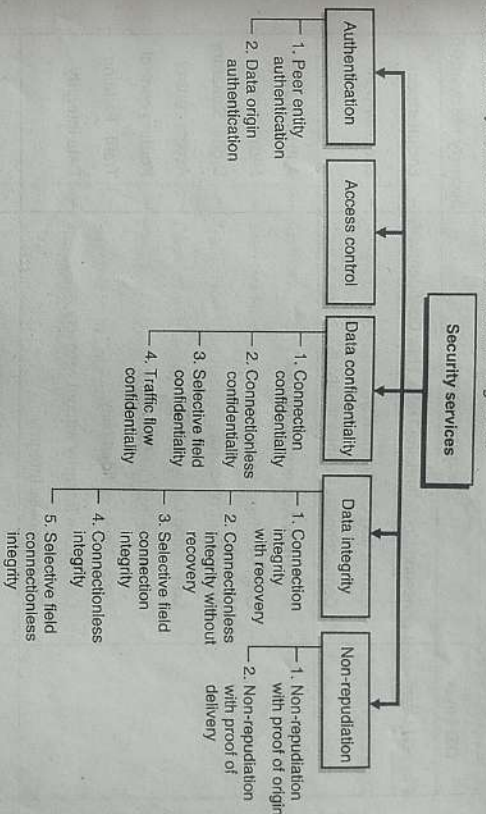


Fig. 1.5.1 : Security services

1.5.3 Security Mechanisms

Definition : Security mechanisms are various techniques recommended to provide security services at the various OSI layers.

The various security mechanisms that can be applied are as following :

- Encipherment (Encryption)
 - o Symmetric
 - o Asymmetric
- Digital Signature
 - o Signing a data unit
 - o Verifying a data unit
- Access control
 - o Passwords
 - o Time of access
 - o Duration of access
 - o Access route
- Data integrity
 - o Sent quantity of data
 - o Received quantity of data

- o Sequencing of data units
- o Time stamping
- Authentication
 - o Handshaking
 - o Cryptographic techniques
- Traffic padding
- Routing Control
- Notarization
- Penasive Security
- Security labels
- Event detection
- Security audit
- Security recovery
- You would learn these techniques throughout this course.

1.5.4 Placement of Security Services and Mechanisms

Now that you have a fair understanding of the various security services and the security mechanisms that can be used at the various OSI layers, let us see recommended placement for them as shown in the Table 1.5.3.

Table 1.5.3

OSI Layer	Security Service	Security Mechanism
Physical Layer	Connection Confidentiality Traffic Flow Confidentiality	Encipherment
Data Link Layer	Connection Confidentiality Connectionless Confidentiality	Encipherment
Network Layer	Peer Entity Authentication Data Origin Authentication Access Control service Connection Confidentiality Connectionless Confidentiality Traffic Flow Confidentiality Connection Integrity without recovery Connectionless Integrity	Authentication Encipherment Digital Signature Access control Routing control Traffic Padding Data integrity
Transport Layer	Peer Entity Authentication Data Origin Authentication Access Control service Connection Confidentiality Connectionless Confidentiality Connection Integrity with recovery Connection Integrity without recovery Connectionless Integrity	Authentication Encipherment Digital Signature Access control Data integrity
Session Layer	No security services are provided in the session layer	Not Applicable
Presentation Layer	Connection Confidentiality Connectionless Confidentiality Selective Field Confidentiality Traffic Flow Confidentiality Peer Entity Authentication Data Origin Authentication Connection Integrity with Recovery Connection Integrity without Recovery elective Field Connection Integrity Connectionless Integrity Selective Field Connectionless Integrity Non-repudiation with Proof of Origin Non-repudiation with Proof of Delivery	Encipherment Digital Signature Data Integrity Notarization

OSI Layer	Security Service	Security Mechanism
Application Layer	Peer Entity Authentication Data Origin Authentication Access Control Service Connection Confidentiality Connectionless Confidentiality Selective Field Confidentiality Traffic Flow Confidentiality Connection Integrity with Recovery Connection Integrity without Recovery Selective Field Connection Integrity Connectionless Integrity Selective Field Connectionless Integrity Non-repudiation with Proof of Origin Non-repudiation with Proof of Delivery	Encipherment Access Control Digital Signature Data integrity Traffic Padding Notarization

1.6 Network Security Model

Definition : Network Security Model (NSM) is a seven-layer model that divides the task of securing a network infrastructure into seven manageable sections.

It is similar to the seven OSI layers. The model is generic and can apply to all security implementation and devices. NSM provides a unified way of securing networks. It is easier to pinpoint issues at the respective NSM layers and address the gaps, if any.

The Table 1.6.1 lists the NSM layers and how they align with the OSI layers. It is important to understand that like the OSI layers, each NSM layer builds on top of the previous layer. If any layer is compromised, the layers above it are disrupted as well. For example, if there is an attack at NSM layer 2, it would disrupt layers above it (3, 4, 5, 6 and 7). Let's learn about each of the NSM layers.

Table 1.6.1

Network Security Model (NSM)	OSI Model (inverted)
Physical	Physical
VLAN	Data Link
ACL	Network
Software	Transport
User	Session
Administrative	Presentation
IT Department	Application

- NSM Layer 1 – Physical :** It works at the physical layer. It ensures to safeguard the physical aspects of network. For example, physical access to the routers, switches or any other networking equipment. There could be several physical forms of physical security such as security alarms, security guards and CCTV.
- NSM Layer 2 – VLAN :** VLAN stands for Virtual Local Area Network. At this layer, the network is segmented

(partitioned) into smaller network chunks to safeguard them individually and to also manage them effectively. It ensures that only authorized devices connect to the provided networks. You could create VLANs department wise, region wise or in any other suitable grouping mechanism based on your site requirements.

3. NSM Layer 3 – ACL : ACL stands for Access Control

List. ACLs are created to allow or deny access based on the network layer from the OSI layer. For example, certain IP ranges (say finance department) might be restricted for access by other devices on the network. ACLs can be created on routers, firewalls and switches and can effectively control the network access as designed and intended.

4. NSM Layer 4 – Software : The software layer is

focused on keeping the device software up to date with the latest upgrades and patches in order to mitigate any known software vulnerabilities. At this layer, the patches are installed to ensure that the software running on the device cannot be exploited. For example, you install security patches on your operating system or update applications on your phone to ensure that you are running the secure version of the software and it does not have any known exploits.

5. NSM Layer 5 – User : This layer deals with the user

access and management. The user layer focuses on the user's training and knowledge about security on the network. The user should understand the basic concepts of network security and should be capable of applying security related judgement. For example, users should be aware of which software to run on the system and which not.

6. NSM Layer 6 – Administrative : The administrative

layer focuses on the training of administrative users. It works very similar to the user layer but focuses primarily on the administrative staff. It provides guidance to the layers below it to adequately protect the network. For example, it can dictate which software is allowed for user consumption.

7. NSM Layer 7 – IT Department : The IT department layer deals directly with the maintenance of all layers and making sure that the entire network works correctly from NSM model. It has several professionals in the team that know to architect and operate a secure network.

1.7 Types of Security Attacks

At a high level, there are two broad categories of security attacks carried over the network – Active attacks and Passive attacks which is shown in Fig. 1.7.1.

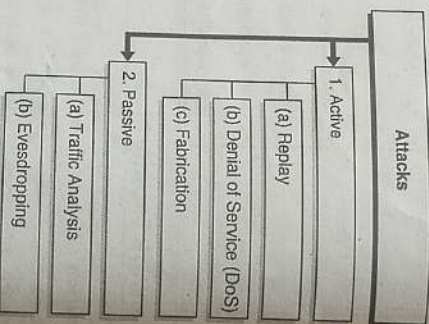


Fig. 1.7.1: Types of Security Attacks

1.7.1 Active Attacks

Definition : An Active attack is defined as, an attack where the attacker actively participates in the communication or the attack mechanism and disrupts the systems by sending several manipulated inputs.

In a nutshell, the attacker intercepts (captures) the communication channel, and manipulates the communication going over it. Another variation of the active attack is when the attacker continuously disrupts the ability of the system to process the information correctly. Let us expand on some of the examples of active attacks.

(a) Replay Attack

This is like replaying a song. The attacker captures the real and specific communication packets, stores them with herself, and then sends it at a later point in time as though she is sending the information for the first time like an authentic information.

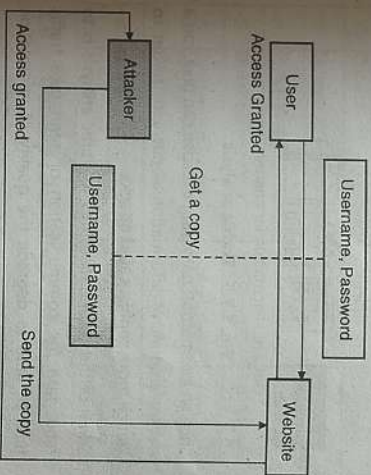


Fig. 1.7.2: Replay attack

For example : Suppose you are sending your username and password to Facebook. Someone can capture that information over the network (even though it is encrypted and unreadable) and without even knowing the actual content of the captured information ever (since it is unreadable) can store it with herself.

At a later point in time, the same captured information can be resent as if it is coming from you and the attacker might get access to your Facebook account.

Countermeasures

You can use timestamps and sequence numbers (also called as session ID). If the message comes with a sequence number that is already used previously, it can be rejected. Similarly, if a message comes with a timestamp that is beyond the estimated threshold, it can be rejected.

(b) Denial of Service (DoS) Attack

Denial of Service (DoS) or its variation Distributed Denial of Service (DDoS) refers to a category of

attacks that can be aimed at various layers of network, operating system, application or other parts of information systems. No crash, usable application

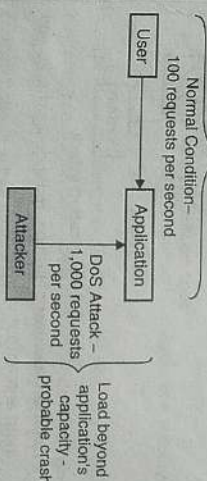


Fig. 1.7.3: Denial of Service (DoS) attack

In this type of attack, the attacker overloads the system beyond its capacity such that the system or controls around it fail. Once the system fails, it is no more available for performing its assigned activities.

For example : An application might be capable of processing a maximum of 100 requests per second. Attacker would typically send over 1,000 requests per second such that the application fails to cope up with it and crashes. The sole motivation behind DoS attacks is to bring down the availability of the system.

Countermeasures : Some of the countermeasures to protect from DoS are firewall, application limit, whitelisting networks etc. Firewall can be used to drop network connections that come from a particular location or based on other networking parameters (a list of allowed IP addresses, etc.). Application limits can protect application from crashing when the rate of requests goes beyond a set limit.

(c) Fabrication Attack

Fabrication attack is again a broad category of active attacks where the attacker deliberately modifies messages, parameters, properties, etc. of information system components and try to alter the behavior of the system often by passing security controls. SQL injection, masquerade and email spoofing are some of the examples of fabrication attacks.

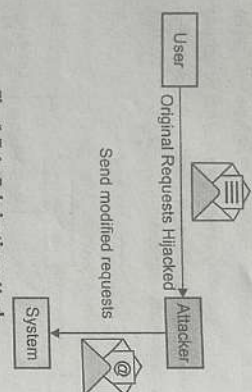


Fig. 1.7.4 : Fabrication attack

Countermeasures : Hashing, redundancy checks, and input and output validation.

You will learn about these techniques in other chapters.

1.7.2 Passive Attacks

Definition : A passive attack is defined as, an attack where the attacker does not alter the behavior of the information system and silently performs her malicious activities.

Unlike active attacks, passive attacks are predominantly used to learn information such as number of systems, how the system operates and behaves under various circumstances and general operational characteristics such as the name and version of the operating system running on the targeted machines. Once the information is gathered, the attacker launches complex and more impactful attacks.

Let us expand on some of the examples of passive attacks :

(a) Traffic Analysis

In traffic analysis, the network traffic and its patterns are watched out over a period of time to infer important information and guess possible activities. For example, following is some information that can be possibly guessed just by knowing the traffic volume and patterns.

- o **Long communication :** It can denote some emergency
- o **Short communications :** It can denote planning, checking and negotiation

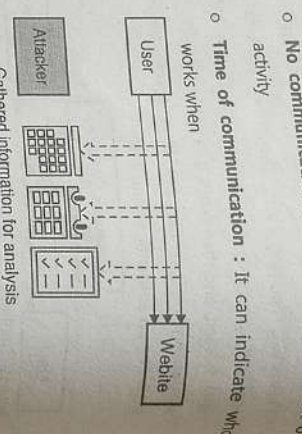


Fig. 1.7.5 : Traffic analysis

Such an information gathering exercise can give you a decent amount of information about your target to launch more sophisticated attacks.

Some of the countermeasures to traffic analysis is to randomize the communication or send fake traffic time to time to degrade the quality of information that the attacker can gather for analysis.

(b) Eavesdropping

Eavesdropping is very similar to over hearing someone's telephonic conversation taking advantage of your proximity to the person.

You can be standing close enough to the person to hear what she is speaking over phone or also hear what the other party on the phone is saying, especially in calm areas.

Similarly, in digital communication, you can wiretap and get a copy of information being communicated and spy on it. Spying on such communication by tapping the information as it is being sent or received is called eavesdropping.

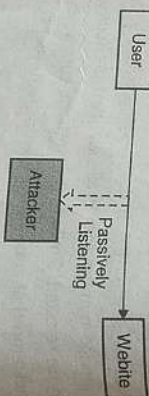


Fig. 1.7.6 : Eavesdropping

Some of the countermeasures to eavesdropping is sending noise time to time or using random channels of communication.

1.7.3 Comparison of Active and Passive Attacks

Sr. No.	Comparison Attribute	Active Attack	Passive Attack
1.	Complexity	High	Low
2.	Impact	High	Low
3.	Detection Possibility	High	Low
4.	Prevention Possibility	High	Low
5.	Duration of attack	Short	Long
6.	System Behavior	Modified	Unaffected
7.	Original Information	Modified	Unaffected
8.	Purpose	Harm the ecosystem	Learn about the ecosystem

1.8 Concept Building - Information Secrecy

Consider a scenario. You and your friend are in different cities and are chatting over phone using an application. You are discussing a new idea to found a startup and have some cool plans that can change the world and make the business very profitable.

But wait, I have two questions for you :

1. How do you know that your conversation (you and your friend sending and receiving text from each other) is not available for anyone else to read?

[Goal : Information not available to everyone]

2. Don't you think that your business plan is confidential and the conversation between you and your friend should somehow remain readable only to you both?

[Goal : Information available to intended entities only]

If you realize the importance of protecting the digital confidential information, you so much wish that there was a way in which you could ensure that the information is available only to you both – blink your eyes and wish granted – Welcome to the world of Cryptography!!

The dictionary meaning of cryptography is “secret writing”.

Digitally speaking,
Definition : Cryptography is a science and a method of storing and transmitting information in a form that only those it is intended for can read and process.

In a nutshell, the information is available in a readable form only to those who are authorized.

Let's take a different example to understand a related concept. You might have used coupon codes in online shopping. Based on the offers running on the website, the coupon code (a set of characters) discounts the price on your chosen items. You apply the coupon code to your cart and based on various terms and conditions, the discount amount is calculated. Sometimes, you get a flat off and sometimes a percentage of the cart value.

In this scenario, we have two interesting concepts :

1. The coupon code (a unique set of alphabets and digits)
2. The coupon code processing terms and conditions (the algorithm (rules) that determines how to apply the coupon code and how much discount to actually give you)

In a different example, you and your friend might have some words (or codes) that are only understood by you both. When you use that word, your friend knows what exactly that really means even if you say it loud and clear and others hear it.

For example : Suppose you both have decided that when you say, “I eat banana”, that would actually mean “Let's bunk college today”. Now, when you say it, your friend gets the real meaning whereas everyone else thinks that you were referring to a fruit.

So, an important concept to understand here is that when the real information is hidden within what is being communicated, the communicated information can be stored or transmitted without disclosing the actual meaning and we don't care if someone gets the communicated information because the real information is hidden. So, real information can freely move around hiding within the communicated information.

1.9 Concept Building - Introduction to Cryptography

Now that you understand some of the scenarios around information secrecy, let's define some the basic terms that we would be using throughout the chapter.

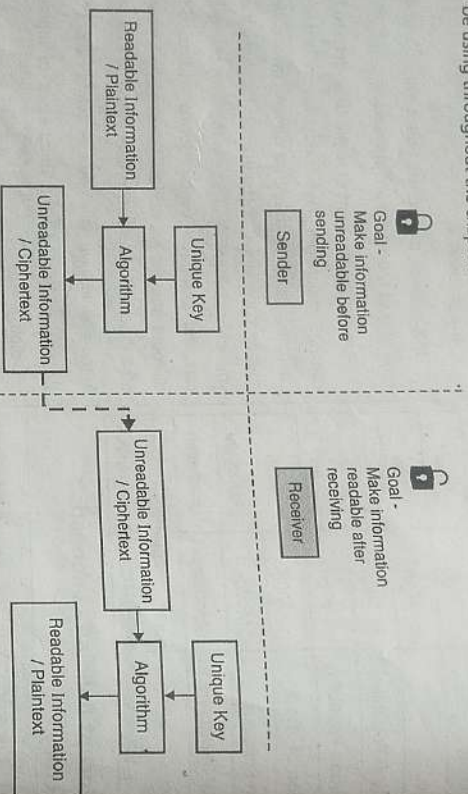


Fig. 1.9.1: How Cryptography Works

- 1. Goal of cryptography :** As you understand, the core goal of cryptography is to hide confidential information. So, cryptography majorly provides Confidentiality out of the CIA triad (Confidentiality, Integrity and Availability).
- 2. Information / Data :** This is the asset that is being protected (provide confidentiality using cryptography in this case). As we discussed in Section 1.1 that an asset is something that has value and is worth protecting. The sender ensures that the information is only readable by the intended receiver even if it is captured / seen by anyone else.
- 3. Unique Key :** This is a set of numbers (like your coupon code) that helps to make the information secret. It is like your usual key that helps to lock and unlock the door. Note here that like various bikes could have the same locking mechanism, a key is unique to a bike even if the bikes are of same model.
- 4. Algorithm :** Algorithm is a process or set of rules to be followed to make the information secret. There are various algorithms (like various types of locks) available that make the information secret in different ways using the keys. In cryptography, such algorithms are also called ciphers.
- 5. Plaintext :** The information that is readable and understandable is called **plaintext**.
- 6. Ciphertext :** The information that is not understandable even if you can read it is called **ciphertext**.
- 7. Encryption (or encipher) :** Encryption is a method of converting plaintext into ciphertext by using an algorithm and a key.

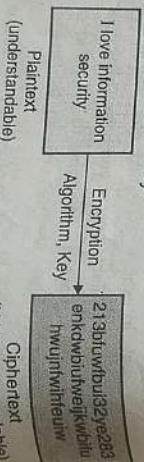


Fig. 1.9.2 : Encryption (or encipher)

- 8. Decryption (or decipher) :** Decryption is a method of converting ciphertext into plaintext by using an algorithm and a key.

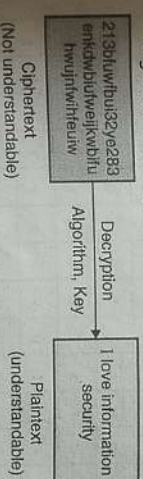


Fig. 1.9.3 : Decryption (or decipher)

Table 1.9.1

Sr. No.	Crypto Entities	Is Secret?	Is understandable?
1.	Plaintext	No (But, need to)	Yes
2.	Ciphertext	No	No
3.	Key	Yes	No
4.	Algorithm	No	Yes

Note : The rest of the sections in this chapter heavily build upon the concepts and the introduction you got. Please take sometime to make yourself familiar and comfortable with the terms before reading further.

1.10 Classical Encryption Techniques

Encryption typically involves two operations as shown in Fig. 1.10.1

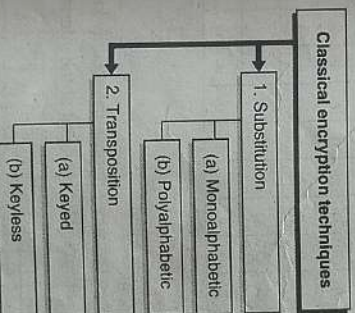


Fig. 1.10.1 : Classical Encryption Techniques

1.10.1 Substitution

In this operation, one character is replaced by another (like substitutes in games).

For example : 'A' can be substituted by 'D' and 'B' can be substituted by 'E' and so on based on a chosen substitution key.

Example

Assume that our substitution key is "shift next by 3". Recall from earlier discussion that the key is preserved secretly. Our algorithm (rule) is simple substitution. Let's apply the key and algorithm and encrypt some plaintext.

Table 1.10.1 : Simple substitution table

Plaintext	Ciphertext
I love cybersecurity	L oryhbehufwfwjkwblu
Apple	Dssoh
23456	56789

The Table 1.10.1 is a simple substitution table where each character in plaintext is moved by 3 characters. Characters such as "y" when shifted, take the form of $y \rightarrow z \rightarrow a, a \rightarrow b$.

The above example is a classical substitution cipher called **Caesar cipher** named after Julius Caesar. This type of substitution cipher is also referred to as a **"monoalphabetic substitution cipher"** because it uses only one character at a time.

Another type of substitution cipher is called **"polyalphabetic substitution cipher"**. In this, more than one alphabet is used at a time for encrypting plaintext. Let's learn a few polyalphabetic substitution ciphers.

1. Vignere Cipher

The Table 1.10.2 shows the Vignere table where alphabets are arranged in rows and columns. It is simple to draw. Just write a-z skipping one alphabet from left, at a time, in a row. First two rows are identical.

Table 10.2: Vignere Cipher

a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a
b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a
c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b
c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b
d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c
d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c
e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d
e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d
f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e
f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e
g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f
g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f
h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g
h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g
i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h
i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h
j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i
j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i
k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j
k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j
l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k
l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k
m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l
m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l
n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m
n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m
o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n
o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n
p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o
p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o
q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p
q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p
r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q
r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q
s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r
s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r
t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s
t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s
u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t
u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t
v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u
v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u
w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v
w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v
x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w
x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w
y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x
y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x
z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y

'Let's take an example,

Plaintext : apple

Security Key : snow

Algorithm : Vignere Cipher

Let's try to find out ciphertext given the information above. You will need to super-impose the security key above the plaintext you wish to encrypt. You would find the ciphertext value for each plaintext character at the intersection of column (from security key value) and row (from plaintext value).

Security Key →	s	n	o	w	← column
Plaintext →	a	p	p	l	e
					← row

Cinbertext would be

First letter (ciphertext of plaintext 'a')

Second letter (ciphertext of plaintext 'p')

Fourth letter (ciphertext of plaintext "I")

Fifth letter (ciphertext of plaintext 'e')

→ Intersection of column 's' and row 'a'	→ Value is 's'
→ Intersection of column 't' and row 'p'	→ Value is 'c'
→ Intersection of column 'o' and row 'p'	→ Value is 'd'
→ Intersection of column 'w' and row 'l'	→ Value is 'h'
→ Intersection of column 's' and row 'e'	→ Value is 'w'

Table 1.10.3: Vignere Cipher Example

Plaintext																										Security Key																									
a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a
c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b
d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c
e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d
f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	
g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d		
h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d			
i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d				
j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d					
k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d						
l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d							
m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d								
n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d									
o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d										
p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d											
q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d												
r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d													
s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d														
t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d															
u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d																
v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d																	
w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d																		
x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d																			
y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d																				
z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d																					

So, the ciphertext for plaintext "apple" with security key "snow" and using algorithm "Vignere cipher" is "scdmw".

2. Playfair Cipher

Definition: The Playfair cipher is a symmetric key based encryption technique that uses digraph substitution cipher.

This technique encrypts the pairs of alphabets (digraphs), instead of single alphabets as in the case of simple substitution ciphers like Caesar cipher. The Playfair cipher is thus significantly harder to break. It involves 625 combinations of alphabet pairs instead of just 26 in the case of single alphabets. Hence, the regular cryptanalysis techniques such as the frequency analysis are harder to perform.

Algorithm

1. Start by creating a 5x5 key square by choosing a key and filling rest of the places by the remaining alphabets such that any alphabet occurs only once in the 5x5 square. 5x5 will cover up only 25 alphabets. Hence, i and j are combined and treated as 1 position. This would then cover all the 26 alphabets in the 5x5 square.
2. Take the plaintext and remove any punctuations, special characters, numbers, etc. such that only alphabets remain in the plaintext. Then make pairs of the alphabets in the plaintext. If you have just one alphabet left out, use X to make a pair. Any pairs that have the same alphabets are also replaced by a X.
3. Use the pairs in plaintext to substitute with the key square positions. Locate the alphabets in the key square and follow the substitution rules:
 - (a) If the alphabets appear on the same row of the key square, replace them with the alphabets to their immediate right respectively. (If the alphabet is in the rightmost corner, wrap around to take the leftmost alphabet of the row).
 - (b) If the alphabets appear on the same column of the key square, replace them with the alphabets immediately below respectively. (If the alphabet is at the bottom most position, wrap around to take the top most alphabet of the column).

- (c) If the alphabets are in different rows and columns, replace the pair with the alphabets on the same row respectively but at the corners of the rectangle defined by the original pair.

Ex. 1.10.1: Use Playfair cipher to encrypt the word "grin" using the key "moon mission".

Soln.:

Step 1: Construct the key square.

Unique alphabets from the given key "moon mission" are $\rightarrow m, o, n, i$ and s, i and j are combined into one cell in the key square. Rest of the alphabets are filled serially such that the alphabets already in the key square (the i and j in the first row) are not repeated. This gives the following 5x5 key square.

m	o	n	i/j	s
a	b	c	d	e
f	g	h	k	l
p	q	r	t	u
v	w	x	y	z

Step 2: Arrange plaintext.

The plaintext to encrypt is "grin". It is ordered as the following pairs.

"gr", "ex", "et"

The 2nd occurrence of e in ee is replaced with x to give

"ex".

Step 3: Apply substitution based on the key square and the plaintext pairs.

"gr" is encrypted as following.

m	o	n	i/j	s
a	b	c	d	e
f	g	h	k	l
p	q	r	t	u
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

- The alphabet in the corner of the rectangle of the same row as g is h.
- The alphabet in the corner of the rectangle of the same row as r is q.

Hence, "gr" is encrypted as "hq".

Now, pick the next plaintext pair "ex".

m	o	n	i/j	s
a	b	c	d	e
f	g	h	k	l
p	q	r	t	u
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

- The alphabet in the corner of the rectangle of the same row as e is c.
- The alphabet in the corner of the rectangle of the same row as x is z.

Hence, "ex" is encrypted as "cz".

Now, pick the next plaintext pair "et".

m	o	n	i/j	s
a	b	c	d	e
f	g	h	k	l
p	q	r	t	u
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

- The alphabet in the corner of the rectangle of the same row as e is d.
- The alphabet in the corner of the rectangle of the same row as t is u.

Hence, "et" is encrypted as "du".

Hence, the plaintext "grin" is encrypted as "hqczdu" using Playfair cipher using the key "moon mission".

Ex. 1.10.2: Use Playfair cipher to encrypt the plaintext "why, don't you?" using the key "keyword".

Soln.:

Step 1: Construct the key square.

k	e	y	w	o
r	d	a	b	c
f	g	h	i/j	l
m	n	p	q	s
t	u	v	x	z

Step 2: Arrange the plaintext into pairs. (remove all punctuations)

"wh", "yd", "on", "ty", "ou"

Step 3: Apply substitution for each plaintext pair.

k	e	y	w	o
r	d	a	b	c
f	g	h	i/j	l
m	n	p	q	s
t	u	v	x	z

"wh" is "yt".

k	e	y	w	o
r	d	a	b	c
f	g	h	i/j	l
m	n	p	q	s
t	u	v	x	z

"yd" is "ea".

k	e	y	w	o
r	d	a	b	c
f	g	h	i/j	l
m	n	p	q	s
t	u	v	x	z

"on" is "es".

k	e	y	w	o
r	d	a	b	c
f	g	h	i/j	l
m	n	p	q	s
t	u	v	x	z

"y" is "wk".

k	e	y	w	o
r	d	a	b	c
f	g	h	i/j	l
m	n	p	q	s
t	u	v	x	z

"ou" is "ex".

Hence, "Why, don't you?" is encrypted as "yieaesykez" using the key "keyword".

Ex. 1.10.3 : Encrypt "This is the final exam" with Playfair cipher using key "Guidance". Explain the steps involved.

Soln. :

Step 1 : Construct the 5 × 5 key square.

All alphabets in the given key "guidance" are unique. i and j are combined into one cell in the key square. Rest of the alphabets are filled serially such that the alphabets already in the key square (the key in the first row) are not repeated. This gives the following 5 × 5 key square.

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

Step 2 : Arrange the plaintext into pairs.

(remove all punctuations).

"Th", "is", "is", "th", "ef", "in", "ai", "ex", "am"

Step 3 : Apply substitution for each plaintext pair.

"th" is encrypted as following :

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

The alphabet in the corner of the rectangle of the same row as t is p

The alphabet in the corner of the rectangle of the same row as h is o

Hence, "th" is encrypted as "po".

Now, pick the next pair, "is" (repeated twice).

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

The alphabet in the corner of the rectangle of the same row as i is d.

The alphabet in the corner of the rectangle of the same row as s is r.

Hence, "is" is encrypted as "dr".

Now, pick the next pair, "th". You have already calculated encrypted text for "th" as "po". So, you can reuse the value.

Now, pick the next pair, "ef".

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets appear on the same row of the key square, replace them with the alphabets to their immediate right respectively. (If the alphabet is in the rightmost corner, wrap around to take the leftmost alphabet of the row).

The alphabet to the right of e is b.

The alphabet to the right of f is n.

Hence, "ef" is encrypted as "bn".

Now, pick the next pair, "in".

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

The alphabet in the corner of the rectangle of the same row as i is g.

The alphabet in the corner of the rectangle of the same row as n is e.

Hence, "in" is encrypted as "ge".

Now, pick the next pair, "ai".

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

The alphabet in the corner of the rectangle of the same row as a is l.

The alphabet in the corner of the rectangle of the same row as i is o.

Hence, "ai" is encrypted as "lo".

Now, pick the next pair, "ex".

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets appear on the same column of the key square. Hence, replace them with the alphabets immediately below respectively. (If the alphabet is at the bottom most position, wrap around to take the topmost alphabet of the column).

The alphabet below e is l.

The alphabet below x is i.

Hence, "ex" is encrypted as "li".

Now, pick the next pair, "am".

g	u	i/j	d	a
n	c	e	b	f
h	k	l	m	o
p	q	r	s	t
v	w	x	y	z

The alphabets to encrypt are in different rows and hence they form a rectangle. You need to pick the corners.

The alphabet in the corner of the rectangle of the same row as a is d.

The alphabet in the corner of the rectangle of the same row as m is o.

Hence, "am" is encrypted as "do".

Now, combine all the encrypted pairs.

Hence, encrypting "This is the final exam" with Playfair cipher using the key "Guidance" gives us the ciphertext as "podirpooheioido".

3. Hill Cipher

Definition : The Hill cipher is a polygraphic substitution cipher based on linear algebra.

By polygraphic, we mean that it can work on substitution for up to 3-alphabets at a time. It arranges the key and the plaintext into a matrix format and their multiplication undergoes the mod 26 operation to find the resultant ciphertext.

Algorithm

1. Arrange the key and the plaintext in a matrix format. Use the following Table 1.10.4 for assigning numbers to alphabets for matrix operations. Note that you need to create the plaintext matrix according to the given key matrix such that multiplication is possible. The number of columns in the key matrix must be equal to the number of rows in the plaintext matrix. If the plaintext is larger, break it up into multiple matrices and apply further steps on each of the plaintext matrix using the key. To fill the matrix, in case you are short of matrix elements, you may use zeroes.

Table 1.10.4

Alphabet	Number	Alphabet	Number
A	0	N	13
B	1	O	14
C	2	P	15
D	3	Q	16
E	4	R	17
F	5	S	18
G	6	T	19
H	7	U	20
I	8	V	21
J	9	W	22
K	10	X	23
L	11	Y	24
M	12	Z	25

1. Carry out multiplication of the key and the plaintext matrix.

2. Perform mod 26 operation on the resultant multiplication.

3. Use the table again to convert numbers back to alphabets. These alphabets represent the ciphertext.

Ex. 1.10.4 : Encrypt the message "Exam" using the key with the key $\begin{bmatrix} 9 & 4 \\ 5 & 7 \end{bmatrix}$.

Soln. : Plaintext "Exam" when converted into a number matrix would be $\begin{bmatrix} 4 & 0 \\ 23 & 12 \end{bmatrix}$

Multiply the key and Plaintext matrices.

$$\begin{bmatrix} 9 & 4 \\ 5 & 7 \end{bmatrix} \times \begin{bmatrix} 4 & 0 \\ 23 & 12 \end{bmatrix} = \begin{bmatrix} 128 & 48 \\ 181 & 84 \end{bmatrix}$$

Perform mod 26 operation on the result.

$$\begin{bmatrix} 128 & 48 \\ 181 & 84 \end{bmatrix} \text{ mod } 26 = \begin{bmatrix} 24 & 22 \\ 25 & 6 \end{bmatrix}$$

Converting the numbers from mod operation back to alphabets you get "YZMG". Hence, encrypting the plaintext "Exam" using the given key gives ciphertext "YZMG".

Ex. 1.10.5 : Encrypt the message "DEF" using the Hill cipher with the key $\begin{bmatrix} 2 & 4 & 5 \\ 9 & 2 & 1 \\ 3 & 8 & 7 \end{bmatrix}$.

Soln. : Plaintext "DEF" when converted into a number matrix would be $\begin{bmatrix} 3 \\ 4 \\ 5 \end{bmatrix}$

Multiply the key and Plaintext matrices.

$$\begin{bmatrix} 2 & 4 & 5 \\ 9 & 2 & 1 \\ 3 & 8 & 7 \end{bmatrix} \times \begin{bmatrix} 3 \\ 4 \\ 5 \end{bmatrix} = \begin{bmatrix} 47 \\ 40 \\ 76 \end{bmatrix}$$

Perform mod 26 operation on the result.

$$\begin{bmatrix} 47 \\ 40 \\ 76 \end{bmatrix} \text{ mod } 26 = \begin{bmatrix} 21 \\ 14 \\ 24 \end{bmatrix}$$

Converting the numbers from mod operation back to alphabets you get "VOY". Hence, encrypting the plaintext "DEF" using the given key gives ciphertext "VOY".

4. Affine Cipher

Definition : Affine cipher is a type of monoalphabetic substitution cipher, wherein each letter in an alphabet is mapped to its numeric equivalent, encrypted using a simple mathematical function, and converted back to a letter.

Each letter is encrypted using the Affine function $(Ax + B) \text{ mod } 26$. Values (A, B) are called coefficients of Affine function. You use the position value of each alphabet and use the Affine function to calculate the position value of the corresponding encrypted letter.

Then, you substitute each plaintext letter with the corresponding encrypted letter from the table. Let's see an example.

Ex. 1.10.6 : Using Affine cipher, encrypt the Plaintext "SECURITY" with key pair (5, 2). **[MU - Dec. 18, 10 Marks]**

Soln. : Here the coefficients of Affine function are (5, 2). So, A = 5 and B = 2.

Create a table of all alphabets using the formula $(Ax + B) \text{ mod } 26$. Use A = 5 and B = 2 for this computation.

Position Value of Alphabet	Plaintext Alphabet	Affine Calculation $(A \times \text{Position} + B) \text{ mod } 26$	Encrypted Alphabet (Position from Affine calculation)
0	A	$(5 \times 0 + 2) \text{ mod } 26 = 2$	C
1	B	$(5 \times 1 + 2) \text{ mod } 26 = 7$	H
2	C	$(5 \times 2 + 2) \text{ mod } 26 = 12$	M
3	D	$(5 \times 3 + 2) \text{ mod } 26 = 17$	R
4	E	$(5 \times 4 + 2) \text{ mod } 26 = 22$	W
5	F	$(5 \times 5 + 2) \text{ mod } 26 = 1$	B
6	G	$(5 \times 6 + 2) \text{ mod } 26 = 6$	G
7	H	$(5 \times 7 + 2) \text{ mod } 26 = 11$	L
8	I	$(5 \times 8 + 2) \text{ mod } 26 = 16$	Q
9	J	$(5 \times 9 + 2) \text{ mod } 26 = 21$	V
10	K	$(5 \times 10 + 2) \text{ mod } 26 = 0$	A
11	L	$(5 \times 11 + 2) \text{ mod } 26 = 5$	F
12	M	$(5 \times 12 + 2) \text{ mod } 26 = 10$	K
13	N	$(5 \times 13 + 2) \text{ mod } 26 = 15$	P
14	O	$(5 \times 14 + 2) \text{ mod } 26 = 20$	U
15	P	$(5 \times 15 + 2) \text{ mod } 26 = 25$	Z
16	Q	$(5 \times 16 + 2) \text{ mod } 26 = 4$	E
17	R	$(5 \times 17 + 2) \text{ mod } 26 = 9$	J
18	S	$(5 \times 18 + 2) \text{ mod } 26 = 14$	O
19	T	$(5 \times 19 + 2) \text{ mod } 26 = 19$	T
20	U	$(5 \times 20 + 2) \text{ mod } 26 = 24$	Y
21	V	$(5 \times 21 + 2) \text{ mod } 26 = 3$	D
22	W	$(5 \times 22 + 2) \text{ mod } 26 = 8$	I

Position Value of Alphabet	Plaintext Alphabet	Affine Calculation (A*Position + B) mod 26	Encrypted Alphabet (Position from Affine calculation)
23	X	$(5 * 23 + 2) \bmod 26 = 13$	N
24	Y	$(5 * 24 + 2) \bmod 26 = 18$	S
25	Z	$(5 * 25 + 2) \bmod 26 = 23$	X

Once the table is ready, you can substitute each letter in the plaintext with its corresponding encrypted letter.

Position Value of Alphabet	Plaintext Alphabet	Affine Calculation (A*Position + B) mod 26	Encrypted Alphabet (Position from Affine calculation)
0	A	$(5 * 0 + 2) \bmod 26 = 2$	C
1	B	$(5 * 1 + 2) \bmod 26 = 7$	H
2	C	$(5 * 2 + 2) \bmod 26 = 12$	M
3	D	$(5 * 3 + 2) \bmod 26 = 17$	R
4	E	$(5 * 4 + 2) \bmod 26 = 22$	W
5	F	$(5 * 5 + 2) \bmod 26 = 1$	B
6	G	$(5 * 6 + 2) \bmod 26 = 6$	G
7	H	$(5 * 7 + 2) \bmod 26 = 11$	L
8	I	$(5 * 8 + 2) \bmod 26 = 16$	Q
9	J	$(5 * 9 + 2) \bmod 26 = 21$	V
10	K	$(5 * 10 + 2) \bmod 26 = 0$	A
11	L	$(5 * 11 + 2) \bmod 26 = 5$	F
12	M	$(5 * 12 + 2) \bmod 26 = 10$	K
13	N	$(5 * 13 + 2) \bmod 26 = 15$	P
14	O	$(5 * 14 + 2) \bmod 26 = 20$	U
15	P	$(5 * 15 + 2) \bmod 26 = 25$	Z
16	Q	$(5 * 16 + 2) \bmod 26 = 4$	E
17	R	$(5 * 17 + 2) \bmod 26 = 9$	J
18	S	$(5 * 18 + 2) \bmod 26 = 14$	O
19	T	$(5 * 19 + 2) \bmod 26 = 19$	T
20	U	$(5 * 20 + 2) \bmod 26 = 24$	Y
21	V	$(5 * 21 + 2) \bmod 26 = 3$	D
22	W	$(5 * 22 + 2) \bmod 26 = 8$	I
23	X	$(5 * 23 + 2) \bmod 26 = 13$	N
24	Y	$(5 * 24 + 2) \bmod 26 = 18$	S
25	Z	$(5 * 25 + 2) \bmod 26 = 23$	X

So,

- S → O
- E → W
- C → M
- U → Y
- R → J
- I → Q
- T → T
- Y → S

So, the plaintext SECURITY, when encrypted using Affine cipher using the Affine coefficients of (5,2), give OWMYQTS as the encrypted text.

Note : If you have to decrypt the ciphertext using Affine cipher, you follow the same approach. You first create the table using the Affine coefficients and then substitute the encrypted letters with their corresponding plaintext letters.

Difference between monoalphabetic and polyalphabetic ciphers

Note a key difference between monoalphabetic cipher and polyalphabetic cipher

- For repeated characters, in monoalphabetic cipher, ciphertext is same (for example, plaintext y is ciphertext b as per example we chose earlier) whereas
- For polyalphabetic cipher, repeated plaintext characters need not lead to the same ciphertext (for example, there are two instances of p in plaintext word apple in the polyalphabetic cipher example. One is encrypted as c and another is encrypted as d).

So, polyalphabetic ciphers are stronger than monoalphabetic since they usually give different ciphertext values for repeated characters in plaintext and hence are less prone to frequency analysis attack. Frequency analysis attack tries to find a correlation between plaintext and ciphertext and determine the security key. For example, the attacker might guess that y is encrypted as b in the monoalphabetic cipher, so it could mean the security key is "shift next by 3". Once the attacker determines the key, converting any

ciphertext back to plaintext is a trivial (very simple) task.

For Cryptography to be successful, keeping the key secret is very important.

1.10.2 Transposition

Q. Explain Transposition Ciphers with illustrative examples. **[10 - Dec. 18, 10 Marks]**

In this operation, the position of characters is jumbled up (mixed up) like a letter arranging game. For example, the plaintext "apple" could be transposed into ciphertext as "elpap". Note that all the characters in plaintext are also present in the ciphertext but at different positions. For example, position of "a" in plaintext is 1, whereas in ciphertext it is 4. Note that it is a very simplistic example. Various complex mathematical transposition algorithms are usually used in cryptography. Transposition can be carried out using two techniques – Keyed and Keyless. Let us learn about them.

1. Keyed Transposition Cipher

Definition : In keyed transposition, a random key is used to describe the transposition sequence and carry out the transposition.

This is also called Columnar Transposition Cipher.

Algorithm

1. Arrange the plaintext in a column under the given key.
2. Rearrange the plaintext column-wise in key's alphabetic order.

Ex 1.10.7 : Use the key "ENCRYPT" to encrypt the plaintext "Save the king from attack" using transposition cipher.

Soln. :

Draw a table and arrange the key and the plaintext under the key column-wise. Mark the alphabets in the key in their order alphabetically. For example, for the given key, the alphabet "C" comes first in the order of 26 alphabets. Then comes "E" and hence marked 2. Likewise mark all the alphabets in the key according to their occurrence in the alphabets.

E	N	C	R	Y	P	T
2	3	1	5	7	4	6
s	a	v	e	t	h	e
k	i	n	g	f	r	o
m	a	t	t	a	c	k

Read the columns in order.

- Take column C marked as 1st in order → vnt
- Take column E marked as 2nd in order → skrn
- Take column N marked as 3rd in order → aia
- Follow likewise to get the ciphertext as "vntskrnaihnregteoktā".

Ex. 1.10.8 : Use the key "SORROW" to encrypt the plaintext "Demonetization tonight" using transposition cipher.

Soln. :

Draw a table and arrange the key and the plaintext as following. Mark the order of the columns from left to right in case of repeated key characters. Pad the columns with 'x' to fill the columns if the plaintext does not fill the table completely.

Ex. 1.10.9 : Encrypt the plaintext "Save the king from attack" using Railfence cipher. Assume a suitable rail size.

Soln. : Assuming a rail size of 3. All it means is that it would have 3 rows. Arrange the plaintext in rails one alphabet at a time.

rail 1 →	s		t		i		r		t		k
rail 2 →	a	e	h	k	n	f	o	a	t	c	
rail 3 →	v			e			m			a	

Rearrange the plaintext rail-wise (row-wise) to get the ciphertext. Start from rail 1, then rail 2 and finally rail 3. Here the ciphertext would be "stirkahknfoatvegna".

Ex. 1.10.10 : Encrypt the plaintext "Demonetization tonight" using Railfence cipher. Assume the rail size of 4.

rail 1 →	d				t				o				g	
rail 2 →		e			e	i				n				
rail 3 →			m		n				z	t			i	h
rail 4 →											n			t

The resulting ciphertext is "dtogeiihnmtzhtao".

S	O	R	R	O	W
5	1	3	4	2	6
d	e	m	o	n	e
t	i	z	a	t	i
o	n	t	o	n	i
g	h	t	x	x	x

The resulting ciphertext is "eihtntmztzhtaoxdgeiix".

2. Keyless Transposition Cipher

Definition : In keyless transposition, transposition sequence is described without a random key.

One such example of Keyless Transposition Cipher is Railfence Cipher. Railfence cipher uses the rail size, a key and does not use a random key as such. It can be easily broken.

Algorithm

1. Based on the rail size, arrange the plaintext.
2. Rearrange the plaintext row-wise to get the ciphertext.

1.1.1 Methods of Encryption

As you know, encryption is primarily driven by two components: Keys and Algorithms. Based on the number of keys used in the encryption and decryption process, the encryption methods can be classified as shown in Fig. 1.11.1.

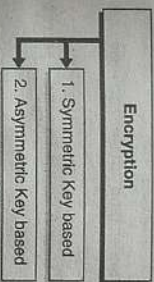


Fig. 1.11.1 : Methods of Encryption

1.1.1.1 Symmetric Key Encryption

Symmetric means same.

Definition : In Symmetric Key Encryption, the key used for encryption is same as the key used for decryption.

The keys are identical. The sender as well as the receiver must have exactly the same key to encrypt or decrypt. As an example, symmetric key is like your regular lock key. The same key can be used for locking the door as well as unlocking the door.

As you understand, a symmetric key is unique between a sender and a receiver. If there are more entities involved and each require to securely communicate with the another, you end up having multiple keys.

Let's take an example, suppose there are 4 friends: A, B, C and D and each one of them require communicating with one another secretly. It is obvious that you cannot share the keys between a pair of friends with another pair of friends. So, if A and B share a key, B and C cannot share the same key because C would also know the secret key between A and B and can then decrypt communication between A and B. So, you would require several keys to ensure that each pair of sender and receiver have a unique key. So, how many keys would you need?

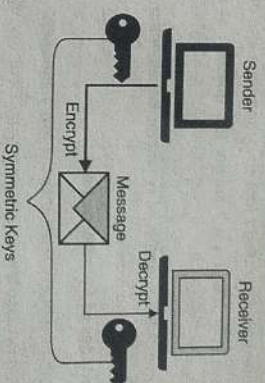


Fig. 1.11.2 : Symmetric Key Encryption

You would need below keys (one for each pair of sender and receiver)

1. A <> B
2. A <> C
3. A <> D
4. B <> C
5. B <> D
6. C <> D



Fig. 1.11.3

This can be effectively calculated using the formula $K = \frac{N(N-1)}{2}$ where 'N' is the number of entities that need to securely communicate. So, in the above example, $K = 4 * (4 - 1) / 2 = 6$. If we have 100 entities, it would require $100 * (100 - 1) / 2 = 4,950$ keys! What if the entire world wants to communicate with each other. Can you imagine? I will come back to it later on and answer that for you.

Another problem here is how does 'A' send the key she is using to 'B'? If the sender and receiver have to use the same key, there should be a way to securely transfer the key. Isn't it?

For example : If you have to give your house keys to your friend, you probably exchange hands in person. You don't leave the key somewhere that could

potentially be picked / looked by someone else other than your friend. I will answer this question as well later on.

Some of the examples of symmetric key algorithm are DES, AES and Blowfish.

Advantages of Symmetric Keys

1. Computationally faster than the asymmetric keys
2. Hard to break if the key used is long

Disadvantages of Symmetric Keys

1. Requires a secure mechanism to exchange keys
2. Each pair of sender and receiver require a unique key
3. Provides only confidentiality but not authenticity and non-repudiation

1.1.1.2 Asymmetric Key Encryption

Unlike symmetric keys,

Definition : In Asymmetric Key Encryption, there are two keys that are mathematically related. If one is used for encryption, then only the corresponding other key can be used for decryption.

Asymmetric means not equal. In the asymmetric system, two mathematically related keys work as key pair. If you use one key for encryption, then you need the other key in the pair for decryption. The encrypting key cannot be used for decryption.

Asymmetric Keys based Cryptography is also called as **Public Key Cryptography**.

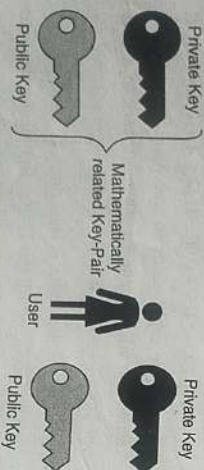


Fig. 1.1.1.4 : Asymmetric Key Encryption

Let's call one of the keys as the Public Key and its counterpart in the pair as the Private Key. A user owns both the keys. The public key is known to the world while the private key is known only to the user.

Table 1.1.1.1

Key Used	Corresponding Key Required	Security Service Provided
Encryption - Public Key	Decryption - Private Key	Confidentiality
Private Key	Public Key	Authentication and Non-repudiation

Let us understand these two use cases of the asymmetric keys.

Use Case 1 : User A wants to send a secret message to User B

- User A knows : User A's Public Key, User A's Private Key, User B's Public Key
- User B knows : User A's Public Key, User B's Private Key, User B's Public Key

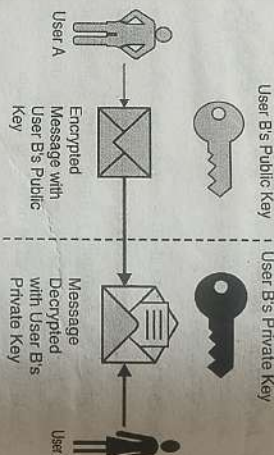


Fig. 1.1.1.5 : Encryption and Decryption using Public Key Cryptography

- User A wants to send an encrypted message such that only User B can read it. User A encrypts the message with User B's Public Key. Now, because User A used User B's Public Key, she is sure that only User B can decrypt the message as decryption would require the corresponding Private Key and only User B knows about her Private Key.

Hence, in this scenario you find that asymmetric keys as well can be used to send encrypted messages as you saw in the case of symmetric keys. One difference to note here is that User A need not know User B's Private Key to send her an encrypted message. A separate key distribution problem does

not exist as Public Keys are known to the world and only the user needs to know and protect her Private Keys.

You also see that you require only two keys per entity for encrypted communication. So, for 100 people to send each other encrypted messages, we would require only 200 keys unlike 4,095 symmetric keys. So, asymmetric keys help you to overcome two of the limitations of symmetric keys :

1. Key distribution and
2. Number of keys to manage

Hence, I answer the question for you that I asked in the previous section – how do we manage keys if the whole world wants to communicate with each other? The answer is using asymmetric keys!

Use Case 2 : Proving authenticity and non-repudiation

The second use case of asymmetric keys is for proving authenticity of an entity. This is highly used today for server validation. Have you seen "https" in front of website addresses? That is one of the examples of this use case.

Suppose, you want to do an online transaction. How do you ensure that the bank's website address you are interacting with is the right one? That's precisely what asymmetric keys help you solve as well.

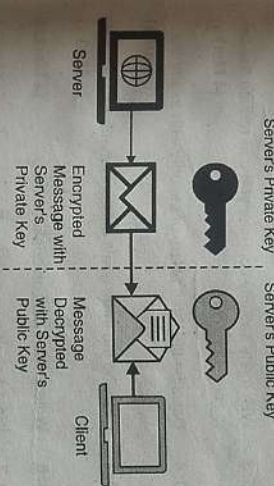


Fig. 1.1.1.6 : Non-repudiation using public key cryptography

Client wants to authenticate the server before it begins the transaction. It sends the server a plaintext message and asks it to encrypt it with its Private Key.

The server encrypts the message that the client sent with its Private Key and sends it back to the client.

Client uses the world-known Public Key of the server and decrypts the message it received from the server. If the message gets successfully decrypted and it matches with what the client sent earlier to the server to encrypt, the client has now validated that it is indeed interacting with the authentic server because except the authentic server, no one else would have known server's Private Key. The client is satisfied, and it begins the secure transaction after having established the server's authenticity.

Hence, you find that asymmetric keys could effectively be used for authentication and non-repudiation. Some examples of algorithms that use asymmetric keys are RSA, ECC, Diffie-Hellman, and El Gamal.

Advantages of Asymmetric Keys

1. Easy key distribution
2. Less number of keys to manage
3. Can also be used for providing authentication and non-repudiation

Disadvantages of Asymmetric Keys

1. Slower than symmetric keys
2. Requires significant CPU power due to complex mathematical relation between the keys

1.1.1.3 Comparison between Symmetric and Asymmetric Keys

Sr. No.	Comparison Attribute	Symmetric Keys	Asymmetric Keys
1.	Speed	High	Low
2.	Complexity	Low	High
3.	Number of keys	High	Low
4.	Key Distribution	Problematic	Easier
5.	Security Services	Confidentiality	Confidentiality, Authenticity, Non-repudiation

1.1.2 Steganography

Definition : *Steganography is the practice of concealing a message within another message, image, or file.*

The information is only hidden and not encrypted. The hiding is so non-obvious that it is difficult to discover it by anyone who is unaware of the presence of the hidden information. Only who knows what to look for and where can look out for the hidden information.

There are many different methods of performing steganography. The most famous of all is the one that modifies only the LSBs (Least Significant Bits). In media files such as images, audio or video, it is difficult to make out any difference between the files with modified LSBs and the files where LSBs are not modified. Hence, the information can be transferred hidden where generally these files are not considered harmful or are thoroughly inspected for finding information transfer. Do you see any difference between the following two images?



That is precisely how hard it is to make out the hidden information where the variations between the two files is extremely hard to make out and not visible to the human eye.

1.1.2.1 Uses of Steganography

1. Leak corporate, business or personal data without being caught by firewall, IDS or other detection mechanisms
2. Sending information in special groups without knowledge of others
3. Attacking users with hidden malicious code in the downloaded media files

1.1.2.2 Comparison between Cryptography and Steganography

Sr. No.	Cryptography	Steganography
1.	The information is transformed	The information is hidden
2.	Transformed information is visible	Hidden information is not visible
3.	Provides Confidentiality, Integrity, Non-repudiation	Provides Confidentiality only
4.	Various recognized and approved algorithms	No such specific algorithms

Review Questions

Here are a few review questions to help you gauge your understanding of this chapter. Try to attempt these questions and ensure that you can recall the points mentioned in the chapter.

Computer Security Concepts

- 1 Explain the terms Assets, Controls, Threats, Vulnerabilities, Risk and Exposure with examples. (6 Marks)
- 2 Draw a block diagram depicting the relation between Assets, Controls, Threats, Vulnerabilities, Risk and Exposure. (6 Marks)
- 3 With many security controls, you can reduce the risk to zero. Comment. (4 Marks)
- 4 Describe the three pillars of security with examples. (6 Marks)
- 5 Describe the three goals of security with examples. (6 Marks)
- 6 Write a short note on confidentiality. (4 Marks)
- 7 Write a short note on integrity. (4 Marks)
- 8 Write a short note on availability. (4 Marks)
- 9 Explain the terms Identification, Authentication, Authorisation, Accountability and Non-repudiation with example. (6 Marks)

- 10 Draw a block diagram depicting the relation between Identification, Authentication, Authorisation and Accountability. (6 Marks)

OSI Model

- 11 Draw a chart for various Security Services provided at various OSI layers. (6 Marks)
- 12 What is OSI Model? List a few Security Services and Mechanisms for each layer. (6 Marks)
- 13 Write a short note on Network Security Model. (4 Marks)

Types of Security Attacks

- 14 Classify security attacks and briefly explain each attack. (6 Marks)
- 15 Describe Replay Attack with a block diagram. (6 Marks)
- 16 Describe Denial of Service (DoS) Attack with a block diagram. (6 Marks)
- 17 Describe Fabrication Attack with a block diagram. (4 Marks)
- 18 Write a short note on traffic analysis. (4 Marks)
- 19 Write a short note on eavesdropping. (4 Marks)
- 20 Compare Active and Passive attacks (4 Marks)

Classical Encryption Techniques

- 21 With an example, explain how you can use substitution for encryption. (6 Marks)
- 22 With an example, explain how you can use transposition for encryption. (6 Marks)

- 23 Take an example of your choice and work it through explaining Vignere Cipher. (8 Marks)
- 24 Take an example of your choice and work it through explaining Playfair Cipher. (8 Marks)
- 25 Take an example of your choice and work it through explaining Hill Cipher. (8 Marks)
- 26 Take an example of your choice and work it through explaining Keyed Transposition Cipher. (8 Marks)
- 27 Take an example of your choice and work it through explaining Keyless Transposition Cipher. (8 Marks)
- 28 Write a short note explaining the difference between monoalphabetic and polyalphabetic cipher. (4 Marks)

Methods of Encryption

- 29 Describe Symmetric Key Encryption. (6 Marks)
- 30 Write advantages and disadvantages of Symmetric Key Encryption. (4 Marks)
- 31 Describe Asymmetric Key Encryption. (6 Marks)
- 32 Write advantages and disadvantages of Asymmetric Key Encryption. (4 Marks)
- 33 Compare symmetric and asymmetric encryption. (4 Marks)
- 34 Describe steganography. (4 Marks)
- 35 Compare steganography and cryptography. (4 Marks)